



ΠΡΟΣΤΑΣΙΑ ΤΗΣ ΙΔΙΩΤΙΚΟΤΗΤΑΣ ΣΤΟ ΔΙΑΔΙΚΤΥΟ ΤΩΝ ΠΡΑΓΜΑΤΩΝ

6^ο εξάμηνο

Στοιχεία Φοιτητών:

Ονοματεπώνυμο	ΑΜ	Email
Έλβις Αβντούλι	E22001	avdulielvis@gmail.com
Γκατζάρα Μαρίνα	E22039	tavraki2004@gmail.com



Περίληψη

Η παρούσα εργασία διερευνά σε βάθος τα ζητήματα προστασίας προσωπικών δεδομένων στο πλαίσιο του Διαδικτύου των Πραγμάτων (IoT). Αφενός, ορίζονται βασικές έννοιες, κατηγοριοποιούνται οι τύποι IoT συσκευών και περιγράφεται το συνολικό οικοσύστημα επικοινωνίας και διαχείρισης δεδομένων. Αφετέρου, εντοπίζονται και αναλύονται οι κύριες απειλές για την ιδιωτικότητα, συμπεριλαμβανομένων τεχνικών επιθέσεων σε επίπεδο δικτύου, παραβιάσεων διαρροής δεδομένων, απειλών ακεραιότητας και πολύπλοκων supply-chain επιθέσεων.

Στη συνέχεια, παρουσιάζονται τα θεσμικά και κανονιστικά πλαίσια (GDPR, ISO/IEC, NIST, ETSI κ.ά.) που ρυθμίζουν την προστασία δεδομένων στο IoT, καθώς και οι βασικές τεχνικές λύσεις—κρυπτογράφηση, ταυτοποίηση & διαχείριση πρόσβασης, ανωνυμοποίηση & pseudonymization—που εφαρμόζονται για τη διασφάλιση της εμπιστευτικότητας, ακεραιότητας και εχεμύθειας. Τέλος, εξετάζονται σύγχρονες τάσεις και προκλήσεις, όπως η ενσωμάτωση AI/ML (π.χ. federated learning) και blockchain, και προτείνονται κατευθύνσεις για την περαιτέρω βελτίωση των μηχανισμών ιδιωτικότητας στις μελλοντικές γενιές IoT συσκευών.



Περιεχόμενα

Περίληψη.....	2
1. Εισαγωγή	5
1.1 Σκοπός της εργασίας	5
1.2 Ορισμοί και ορολογία	6
2. Φιλτράρισμα και Κατηγοριοποίηση του IoT	7
2.1 Τύποι συσκευών IoT	7
2.2 Το οικοσύστημα IoT	8
3. Ιδιωτικότητα και Απειλές στο IoT.....	9
3.1 Κύριες απειλές.....	9
3.1.1 Τεχνικές Επιθέσεις σε Επίπεδο Δικτύου και Πρωτοκόλλων	10
3.1.2 Απειλές Παραβίασης Ιδιωτικότητας	10
3.1.3 Απειλές Ακεραιότητας & Διαθεσιμότητας	11
3.1.4 Πολυεπίπεδες & Supply-Chain Επιθέσεις	11
3.2. Παραδείγματα παραβίασης προσωπικών δεδομένων	11
4. Νομοθετικά και Κανονιστικά Πλαίσια	12
4.1. Ευρωπαϊκό Γενικό Κανονιστικό Πλαίσιο (GDPR)	12
4.1.1. Βασικές Αρχές GDPR Εφαρμοσμένες στο IoT.....	12
4.1.2. Δικαιώματα των Υποκειμένων Δεδομένων.....	13
4.1.3. Υποχρεώσεις Υπευθύνων & Εκτελούντων	14
4.2. Άλλοι διεθνείς κανόνες και προδιαγραφές	14
4.2.1. Οδηγίες ΟΟΣΑ για τη διασυνοριακή ροή προσωπικών δεδομένων.....	14
4.2.2. Πρότυπα ISO/IEC	15
4.2.3. Κατευθύνσεις NIST για το IoT.....	15
4.2.4. ETSI EN 303 645: Βασικές απαιτήσεις κυβερνοασφάλειας	15
4.2.5. ITU-T Recommendations για το IoT	16
4.2.6. IEEE P2413 και Συναφείς Πρωτοβουλίες	16
5. Τεχνικές Προστασίας Ιδιωτικότητας	16
5.1 Κρυπτογράφηση δεδομένων	16
5.2 Διαχείριση Πρόσβασης και Ταυτοποίηση.....	18
5.3 Ανωνυμοποίηση και Pseudonymization	19
6. Προκλήσεις και Μελλοντικές Τάσεις	20



6.1 AI/ML στο IoT και Ιδιωτικότητα	21
6.1.1 Ανίχνευση Απειλών με AI/ML.....	21
6.1.2 Νέοι Κίνδυνοι για την Ιδιωτικότητα	21
6.1.3 Federated Learning και Προστασία Δεδομένων	22
6.1.4 Μελλοντικές Προκλήσεις	22
6.2 Blockchain και διασφαλίσεις.....	22
Συμπέρασμα.....	23
Αναφορές	25



1. Εισαγωγή

1.1 Σκοπός της εργασίας

Η παρούσα εργασία αποσκοπεί στην ανάδειξη διαφόρων ζητημάτων προστασίας προσωπικών δεδομένων στα έξυπνα συστήματα μέσω του διαδικτύου των πραγμάτων.

Πιο συγκεκριμένα:

- **Κατανόηση βασικών εννοιών *Internet of Things*:** Θα εξηγηθούν συνοπτικά βασικές έννοιες και τύποι IoT συσκευών αλλά θα περιγραφεί και η διαδικασία συλλογής, μετάδοσης και αποθήκευσης δεδομένων.
- **Εντοπισμός απειλών για την ιδιωτικότητα:** Θα αναφερθούν διάφορα περιστατικά παραβίασης προσωπικών δεδομένων μέσω τέτοιων συσκευών, μέσα από μελέτες περιπτώσεων.
- **Αξιολόγηση νομικού πλαισίου:** Θα εξεταστεί το Ευρωπαϊκό Γενικό Κανονιστικό Πλαίσιο (GDPR) και θα συγκριθεί με αντίστοιχους κανονισμούς σε ΗΠΑ και Ασία, και θα αναλυθούν οι διαφορές μεταξύ τους.
- **Μελέτη των διαθέσιμων τεχνικών λύσεων:** Θα παρουσιαστούν βασικοί τρόποι διατήρησης ιδιωτικότητας μέσω της κρυπτογράφησης, τα συστήματα ελέγχου πρόσβασης και τεχνικών ανωνυμοποίησης – ψευδωνυμοποίησης.
- **Προτάσεις για το μέλλον:** Να προσδιοριστούν κενά που υπάρχουν και να προταθούν κατευθύνσεις για την βελτίωση των μηχανισμών προστασίας προσωπικών δεδομένων στις νέες γενιές IoT συσκευών.



1.2 Ορισμοί και ορολογία

Internet of Things (IoT): Σαν «Internet of Things (IoT)» ορίζεται ένα σύνολο φυσικών αντικειμένων («things») – κάθε ένα εξοπλισμένο με αισθητήρες, λογισμικό ή άλλες τεχνολογίες – που μπορούν να συγκεντρώνουν, να ανταλλάσσουν και να διαμοιράζουν δεδομένα μέσω δικτύου Internet, χωρίς να απαιτείται άμεση ανθρώπινη παρέμβαση. ^[1]

Προσωπικά Δεδομένα (Personal Data): Σύμφωνα με τον Ευρωπαϊκό Γενικό Κανονισμό για την Προστασία Δεδομένων (GDPR), «προσωπικά δεδομένα» ονομάζονται οποιεσδήποτε πληροφορίες αφορούν σε ταυτοποιημένο ή ταυτοποιήσιμο φυσικό πρόσωπο (data subject). ^[5]

Υποκείμενο Δεδομένων (Data Subject): Φυσικό πρόσωπο στο οποίο αναφέρονται τα δεδομένα. ^[5]

Υπεύθυνος Επεξεργασίας (Data Controller): Φυσικό ή νομικό πρόσωπο που καθορίζει τους σκοπούς και τα μέσα επεξεργασίας προσωπικών δεδομένων. ^[5]

Εκτελών Επεξεργασία (Data Processor): Φυσικό ή νομικό πρόσωπο που επεξεργάζεται δεδομένα για λογαριασμό του υπεύθυνου επεξεργασίας. ^[5]

Ψευδωνυμοποίηση (Pseudonymisation): Διαδικασία με την οποία τα προσωπικά δεδομένα μετασχηματίζονται έτσι ώστε να μην μπορούν να αποδοθούν σε συγκεκριμένο υποκείμενο χωρίς την πρόσθετη χρήση ξεχωριστών πληροφοριών. ^[5]

Ανωνυμοποίηση (Anonymisation): Μόνιμη μετατροπή των δεδομένων ώστε να καθίσταται αδύνατη η ταυτοποίηση του υποκειμένου, ακόμα και μέσω συνδυασμού με άλλες πληροφορίες. Τεχνικές και ορολογία περιγράφονται στο πρότυπο ISO/IEC 20889:2018.



2. Φιλτράρισμα και Κατηγοριοποίηση του IoT

2.1 Τύποι συσκευών IoT

Το Διαδίκτυο των πραγμάτων περιλαμβάνει μια γκάμα ηλεκτρονικών συσκευών, οι οποίες κατατάσσονται τόσο στο πεδίο εφαρμογής όσο και στο επίπεδο των δεδομένων που συλλέγει και επεξεργάζεται. Μερικές κύριες κατηγορίες αποτελούν:

Καταναλωτικές συσκευές: Στον οικιακό χώρο, οι συσκευές IoT προσφέρουν άνεση και εξοικονόμηση ενέργειας με την χρήση συσκευών όπως έξυπνους θερμοστάτες, συνδεδεμένοι φωτισμοί, smart TVs και ψηφιακοί βοηθοί (πχ Amazon Alexa). Για να επιτύχουν τον σκοπό τους βασίζονται σε Wifi και σε διάφορες διεπαφές μέσω εφαρμογών κινητού συνήθως. [\[2\]](#)

Wearable συσκευές: Οι wearable συσκευές παρακολουθούν βιομετρικά δεδομένα και την φυσική δραστηριότητα των χρηστών σε πραγματικό χρόνο. Μέσω αισθητήρων καρδιακού ρυθμού, GPS, επιταχυνσιόμετρα συσκευές όπως fitness trackers, smartwatches ή έξυπνα γυαλιά στέλνουν δεδομένα στο cloud για ανάλυση. [\[2\]](#)

Βιομηχανικό IoT: Οι συσκευές IoT στην παραγωγική διαδικασία αυτοματιοποιούν διαδικασίες και επιτηρούν κρίσιμα μηχανήματα σε βιομηχανικά περιβάλλοντα μέσω αισθητήρων για πρόγνωση βλάβης, έξυπνα ρομπότ και SCADA (Supervisory Control And Data Acquisition) μέσω υπηρεσιών cloud. Κύρια χαρακτηριστικά τους αποτελούν η υψηλή διαθεσιμότητα και η αξιοπιστία που παρέχουν μέσω διαφόρων πρωτοκόλλων. [\[3\]](#)

Υγειονομικό IoT: Σε νοσοκομεία και στην οικιακή περίθαλψη, οι IoT συσκευές όπως φορητοί αισθητήρες γλυκόζη και έξυπνα πιεσόμετρα υποστηρίζουν τηλειατρική και διαχείριση ασθενών. [\[2\]](#)

Έξυπνες Πόλεις: Οι έξυπνες πόλεις περιλαμβάνουν αισθητήρες για την κυκλοφορία, τον φωτισμό, τα απορρίμματα και την ποιότητα αέρα οι οποίες διαχειρίζονται μαζικά από μεγάλες πλατφόρμες. [\[3\]](#)

Αγροτικό IoT: Στην αγροτική ανάπτυξη, οι συσκευές IoT βελτιστοποιούν την



παραγωγή με την χρήση αυτόματου ποτίσματος, αισθητήρων εδάφους, drones έξυπνες θερμοκοιτίδες και πολλά άλλα. Συνήθως τροφοδοτούνται με ηλιακή ενέργεια και είναι αυτόνομες.^[3]

2.2 Το οικοσύστημα IoT

Το οικοσύστημα του IoT δεν περιορίζεται μόνο στις συσκευές. Είναι ένα πολύπλοκο διασυνδεδεμένο δίκτυο τεχνολογιών λογισμικού, πρωτοκόλλων, χρηστών και παρόχων υπηρεσιών που συνεργάζονται για την συλλογή, μετάδοση, ανάλυση και αξιοποίηση δεδομένων. Η κατανόηση αυτού του οικοσυστήματος είναι θεμελιώδης για την μελέτη της ιδιωτικότητας, αφού κάθε επίπεδο ενέχει κινδύνους διαρροής η κακής χρήσης προσωπικών δεδομένων.^[2]

Τα κύρια στοιχεία του είναι:

Συσκευές και αισθητήρες: Αποτελούν το πρώτο επίπεδο του οικοσυστήματος, όπου οι αισθητήρες συλλέγουν δεδομένα όπως θερμοκρασία, φωνή, κίνηση, τοποθεσία, biometrics κλπ.^[2]

Δίκτυα Μετάδοσης: Η επικοινωνία μεταξύ των συσκευών και cloud γίνεται μέσω δικτύων όπως Wi-Fi, Bluetooth, Zigbee, 5G, NB-IoT, ή LoRaWAN. Κάθε τεχνολογία προσφέρει διαφορετικό επίπεδο κάλυψης, ταχύτητας και ασφάλειας.^[8]

Πλατφόρμες Διαχείρισης: Πλατφόρμες όπως AWS IoT, Google Cloud IoT η Microsoft Azure IoT παρέχουν τις υποδομές για την επεξεργασία, αποθήκευση και οπτικοποίηση δεδομένων.^[3]

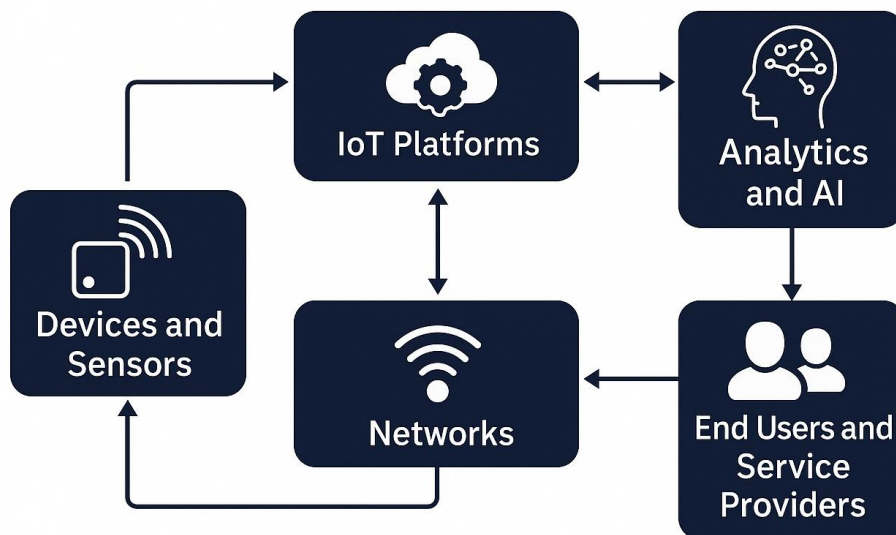
Analytics και Τεχνητή Νοημοσύνη: Για την πρόβλεψη γεγονότων, την βελτιστοποίηση συστημάτων και την προσαρμογή των υπηρεσιών στον χρήστη η τεχνητή νοημοσύνη και η ανάλυση δεδομένων αποτελεί ένα σημαντικό κομμάτι του οικοσυστήματος.^[10]

Τελικοί Χρήστες και Πάροχοι Υπηρεσιών: Οι χρήστες αλληλεπιδρούν με τις

συσκευές, συχνά χωρίς πλήρη επίγνωση του όγκου και του τύπου δεδομένων που χρησιμοποιούνται και οι πάροχοι υπηρεσιών διαχειρίζονται την ασφάλεια και την συμμόρφωση με ρυθμιστικά πλαίσια. [\[9\]](#)

Το οικοσύστημα του IoT είναι πολύπλοκο. Από την παρακολούθηση των φυσικών παραμέτρων μέχρι τη λήψη αποφάσεων με AI, κάθε στοιχείο φέρει ιδιαίτερες προκλήσεις ιδιωτικότητας. Η αποτελεσματική προστασία των προσωπικών δεδομένων δεν μπορεί να περιοριστεί μόνο στη συσκευή, αλλά πρέπει να καλύπτει ολόκληρη την αρχιτεκτονική του οικοσυστήματος.

IoT Ecosystem



3. Ιδιωτικότητα και Απειλές στο IoT

3.1 Κύριες απειλές

Οι βασικές απειλές μπορούν να καταταγούν σε 4 ομάδες, τις τεχνικές επίθεσης σε επίπεδο δικτύου και πρωτοκόλλων, τις απειλές παραβίασης ιδιωτικότητας, της απειλές ακεραιότητας και διαθεσιμότητας και της πολυεπίπεδες και supply chain επιθέσεις.



3.1.1 Τεχνικές Επιθέσεις σε Επίπεδο Δικτύου και Πρωτοκόλλων

Μη Εξουσιοδοτημένη Πρόσβαση: οι επιτιθέμενοι εκμεταλλεύονται αδύναμα ή προεπιλεγμένα διαπιστευτήρια, καθώς και vulnerabilities στα πρωτόκολλα επικοινωνίας, για να αποκτήσουν πρόσβαση σε εσωτερικά δίκτυα ή ευαίσθητα δεδομένα. [\[4\]\[5\]](#)

Data Injection: Ο ελλιπής έλεγχος εγκυρότητας εισόδου επιτρέπει σε επιτιθέμενους να στέλνει πλαστά σήματα και μετρήσεις, ώστε να επηρεαστεί η λήψη των αποφάσεων από τα αυτόματα συστήματα και να εκτελεστούν άλλες ενέργειες. [\[2\]\[8\]](#)

Replay Attacks: Οι επιτιθέμενοι καταγράφουν έγκυρα μηνύματα και στέλνουν σε μεταγενέστερο χρόνο ώστε να παρακάμψουν μηχανισμούς αυθεντικοποίησης και να προκαλέσουν ανεπιθύμητες καταστάσεις. [\[4\]\[5\]](#)

DDos Attacks: Οι IoT συσκευές έχουν μικρή διαθεσιμότητα πόρων. Σαν αποτέλεσμα, είναι ευάλωτες στη διαδικασία επεξεργασίας των πόρων του συστήματος, κάτι που μπορεί να προκαλέσει προσωρινή μη διαθεσιμότητα κρίσιμων υπηρεσιών. [\[3\]\[5\]](#)

3.1.2 Απειλές Παραβίασης Ιδιωτικότητας

Υποκλοπή δεδομένων: Η μετάδοση ευαίσθητων πληροφοριών με απουσία έστω στοιχειώδους κρυπτογράφησης, καθιστά δυνατή την υποκλοπή από τρίτους. Με αυτόν τον τρόπο, είναι πολύ πιθανό να διαρρεύσουν προσωπικά δεδομένα χρηστών.

User Profiling: Συνδυάζοντας δεδομένα από πολλαπλές συσκευές όπως wearables, αισθητήρες, κάμερες μπορούμε να βρούμε πληροφορίες όπως συνήθειες, η ευαίσθητα δεδομένα για την υγεία ενός ατόμου. Τέτοια δεδομένα μπορούν να χρησιμοποιηθούν για στοχευμένες διαφημίσεις ή και χειραγώγηση της συμπεριφοράς των χρηστών. [\[4\]\[5\]](#)

Συσχέτιση Δεδομένων: Με την κατάλληλη επεξεργασία δεδομένων από πολλαπλές IoT συσκευές μπορούμε να αποκαλύψουμε κρυφές πληροφορίες όπως ωράρια απουσίας ή κενά ασφαλείας σε ένα έξυπνο σπίτι. [\[10\]\[5\]](#)



3.1.3 Απειλές Ακεραιότητας & Διαθεσιμότητας

Παραβίαση Firmware / Hardware: Οι επιτηθέμενοι μέσω θυρών IoT συσκευών μπορούν να εγκαταστήσουν backdoors ή rootkits στο hardware παρακάμπτοντας όλους τους μηχανισμούς ασφαλείας. [\[5\]\[12\]](#)

Αλλοίωση Δεδομένων: Οι επιτηθέμενοι μπορούν να τροποποιήσουν τα log files στο edge και στο cloud ή τις μετρήσεις διάφορων αισθητήρων, αλλάζοντας τις λήψεις αποφάσεων διαφόρων αυτοματισμών. [\[12\]](#)

3.1.4 Πολυεπίπεδες & Supply-Chain Επιθέσεις

Multi-Stage Attacks: Συνδυασμός διαφόρων ειδών επιθέσεων σε διάφορα στρώματα του IoT οικοσυστήματος (πχ cloud), δυσχεραίνουν την ανίχνευση και αντιμετώπιση των επιθέσεων. [\[4\]\[11\]](#)

Supply Chain Attacks: Οι επιτηθέμενοι μπορούν να “φυτέψουν” κακόβουλο λογισμικό, μολύνοντας την συσκευή πριν καν φτάσει στον τελικό χρήστη. Τέτοιες επιθέσεις δεν είναι αντιληπτές από τον κατασκευαστή παρά μόνο όταν είναι πολύ αργά. [\[4\]\[12\]](#)

3.2. Παραδείγματα παραβίασης προσωπικών δεδομένων

Ακολουθούν κάποια χαρακτηριστικά περιστατικά παραβιάσεων ευαίσθητων δεδομένων που οι επιτηθέμενοι απέκτησαν πρόσβαση σε συστήματα μέσω ευπαθειών συσκευών IoT.

Wearables FitBit & Apple Watch: το 2021, υπήρξε διαρροή δεδομένων μιας βάσης και 61 εκατομμύρια αρχεία χρηστών FitBit και Apple watch, συμπεριλαμβανομένων μεταδεδομένων άσκησης και πληροφοριών τοποθεσίας. [\[13\]](#)



Κάμερες Ασφαλείας Ring: Υπάλληλοι της Ring είχαν πρόσβαση σε χιλιάδες βίντεο εσωτερικών χωρίς ρητή συγκατάθεση, ενώ χάκερς κατάφεραν να καταγράψουν ζωντανά feeds και να παρενοχλούν ιδιοκτήτες. [\[14\]](#)

Έξυπνες Λάμπες Mars Hydro: Τον Φλεβάρη του 2025, 2,7 δισεκατομμύρια εγγραφές ευαίσθητων δεδομένων ήταν προσβάσιμες σε ανοιχτή βάση δεδομένων της κινεζικής Mars Hydro. [\[15\]](#)

Οικιακές συσκευές Botnets: Έρευνα Gartner δείχνει ότι το 40% των έξυπνων οικιακών συσκευών χρησιμοποιήθηκαν σε botnet επιθέσεις, αξιοποιώντας default credentials και αδύναμους κωδικούς. [\[16\]](#)

Έξυπνες κλειδαριές August Smart Lock: Παλαιότερα μοντέλα της συγκεκριμένης έξυπνης κλειδαριάς άφηναν ευάλωτο το οικιακό δίκτυο σε χάκερς μέχρι τον Δεκέμβριο του 2019. [\[17\]](#)

4. Νομοθετικά και Κανονιστικά Πλαίσια

4.1. Ευρωπαϊκό Γενικό Κανονιστικό Πλαίσιο (GDPR)

Ο GDPR εφαρμόζεται σε κάθε συσκευή ή υπηρεσία IoT που συλλέγει και επεξεργάζεται δεδομένα φυσικών προσώπων εντός ΕΕ, ανεξαρτήτως της έδρας του παρόχου [\[6\]](#) [\[7\]](#). Σε σχέση με τις παραδοσιακές εφαρμογές, οι συσκευές IoT δημιουργούν και διαχειρίζονται όγκο δεδομένων πολύ μεγαλύτερο και πιο πολύπλοκο, συχνά αυτόματα και χωρίς άμεσο έλεγχο από τον χρήστη. Η υιοθέτηση ενός αυστηρού νομικού πλαισίου είναι απαραίτητη για να εξασφαλιστεί η διαφάνεια, η συναίνεση και η ελευθερία άσκησης των δικαιωμάτων των υποκειμένων δεδομένων.

4.1.1. Βασικές Αρχές GDPR Εφαρμοσμένες στο IoT

- **Privacy by Design & Privacy by Default:** Από το αρχικό στάδιο σχεδιασμού και ως προεπιλεγμένη ρύθμιση, τα συστήματα IoT πρέπει να συλλέγουν μόνο τα απολύτως απαραίτητα δεδομένα, περιορίζοντας εκ των προτέρων κάθε υπερβολική ή μη δικαιολογημένη επεξεργασία. [\[6\]](#)



- **Νομιμότητα, Δικαιοσύνη & Διαφάνεια:** Κάθε επεξεργασία δεδομένων πρέπει να στηρίζεται σε σαφή νομική βάση, όπως ρητή συναίνεση του υποκειμένου ή συμβατική αναγκαιότητα. Ο χρήστης πρέπει να ενημερώνεται με κατανοητό και πλήρες τρόπο για το ποια δεδομένα συλλέγονται, πώς χρησιμοποιούνται και για ποιο σκοπό [\[6\]](#) [\[7\]](#).
- **Ελάχιστη Συλλογή & Περιορισμένη Διατήρηση:** Οι συσκευές IoT δεν επιτρέπεται να συγκεντρώνουν περισσότερα δεδομένα από όσα απαιτούνται. Επιπλέον, τα δεδομένα πρέπει να διατηρούνται μόνο για τον ελάχιστο αναγκαίο χρόνο, σύμφωνα με τους σκοπούς που έχουν κοινοποιηθεί στον χρήστη. [\[6\]](#)
- **Ακεραιότητα & Εχεμύθεια:** Πρέπει να υιοθετούνται τεχνικά (π.χ. κρυπτογράφηση από άκρο σε άκρο) και οργανωτικά μέτρα (π.χ. ψευδωνυμοποίηση) για να διασφαλίζεται η αμεταβλητότητα και η εχεμύθεια των δεδομένων κατά τη μεταφορά και αποθήκευση [\[6\]](#) [\[7\]](#).

4.1.2. Δικαιώματα των Υποκειμένων Δεδομένων

Κάθε πλατφόρμα και κάθε συσκευή IoT οφείλει να υποστηρίζει εύκολα και αξιόπιστα τα εξής δικαιώματα:

1. **Δικαίωμα Πρόσβασης:** Ο χρήστης μπορεί να λάβει λεπτομερή εικόνα για τα δεδομένα που τον αφορούν και τον τρόπο επεξεργασίας τους.
2. **Δικαίωμα Διόρθωσης:** Δυνατότητα διόρθωσης οποιουδήποτε ανακριβούς ή ελλιπούς στοιχείου.
3. **Δικαίωμα Διαγραφής:** Αφαίρεση των προσωπικών δεδομένων υπό τις προβλεπόμενες προϋποθέσεις.
4. **Δικαίωμα Περιορισμού Επεξεργασίας:** Αναστολή της επεξεργασίας όταν αμφισβητείται η ακρίβεια ή η νομιμότητα των δεδομένων.
5. **Δικαίωμα Εναντίωσης:** Αντιρρήσεις στην επεξεργασία βάσει νόμιμου συμφέροντος ή δημοσίου συμφέροντος.
6. **Δικαίωμα Φορητότητας:** Παροχή των δεδομένων σε δομημένο, συνηθισμένο και αναγνώσιμο ψηφιακό μορφότυπο, ώστε να μπορεί ο χρήστης να τα μεταφέρει σε άλλο πάροχο [\[6\]](#) [\[7\]](#).

Οι διεπαφές των συσκευών πρέπει να σχεδιάζονται με γνώμονα τη σαφήνεια και την ευχρηστία, ώστε ο χρήστης να ασκεί απρόσκοπτα τα δικαιώματά του.



4.1.3. Υποχρεώσεις Υπευθύνων & Εκτελούντων

Εκτίμηση Επιπτώσεων στην Προστασία Δεδομένων (DPIA):

Πριν από την εμπορική διάθεση ή την ενεργοποίηση υπηρεσιών IoT υψηλού κινδύνου (π.χ. βιομετρικά, τοποθεσιακά δεδομένα), πρέπει να εκτελείται λεπτομερής αξιολόγηση των κινδύνων και να λαμβάνονται κατάλληλα μέτρα μετριασμού [\[6\]](#).

Τήρηση Μητρώου Επεξεργασίας: Καταγραφή όλων των δραστηριοτήτων επεξεργασίας, ώστε να διασφαλίζεται πλήρης ιχνηλασιμότητα και λογοδοσία.

Διορισμός Υπευθύνου Προστασίας Δεδομένων (DPO): Σε περιπτώσεις συστηματικής παρακολούθησης ή μαζικής επεξεργασίας ειδικών κατηγοριών δεδομένων, απαιτείται η ύπαρξη εξειδικευμένου DPO για την επίβλεψη της συμμόρφωσης [\[7\]](#).

Ειδοποίηση Παραβιάσεων: Ο υπεύθυνος επεξεργασίας οφείλει να ενημερώνει την αρμόδια εποπτική αρχή εντός 72 ωρών από τον εντοπισμό κάθε σημαντικής παραβίασης προσωπικών δεδομένων. Αν η παραβίαση ενέχει υψηλό κίνδυνο για τα δικαιώματα των χρηστών, πρέπει να ενημερωθούν και οι ίδιοι άμεσα [\[6\]\[7\]](#).

Επιβολή Κυρώσεων: Σε περιπτώσεις σοβαρής μη συμμόρφωσης, προβλέπονται πρόστιμα έως 20 εκατομμυρίων ευρώ ή 4 % του ετήσιου παγκόσμιου κύκλου εργασιών —όποιο ποσό είναι υψηλότερο— διασφαλίζοντας την αποτελεσματική εφαρμογή των κανόνων. [\[6\]](#)

4.2. Άλλοι διεθνείς κανόνες και προδιαγραφές

Στη διεθνή σκηνή, πέραν του GDPR, υπάρχουν σημαντικά κανονιστικά πλαίσια και πρότυπα που στοχεύουν στην ασφάλεια, την προστασία ιδιωτικότητας και τη διαλειτουργικότητα των συστημάτων IoT. Οι κυριότεροι φορείς και πρότυπα που ακολουθούνται σήμερα περιλαμβάνουν τις Οδηγίες του ΟΟΣΑ, τα διεθνή πρότυπα ISO/IEC, τις κατευθύνσεις του NIST, το ευρωπαϊκό ETSI EN 303 645, τις Τεχνικές Συστάσεις ITU-T και το αρχιτεκτονικό πλαίσιο IEEE P2413.

4.2.1. Οδηγίες ΟΟΣΑ για τη διασυνοριακή ροή προσωπικών δεδομένων

Οι *Guidelines Governing the Protection of Privacy and Transborder Flows of Personal Data* του ΟΟΣΑ καθιερώνουν βασικές αρχές όπως ο περιορισμός συλλογής, η



ποιότητα δεδομένων, ο σκοπός επεξεργασίας, τα μέτρα ασφάλειας και η λογοδοσία [\[18\]](#). Η αναθεώρηση του 2013 ενισχύει ιδιαίτερα την ανάγκη διαλειτουργικότητας μεταξύ εθνικών νομοθεσιών και τη διασυνοριακή συνεργασία [\[19\]](#).

4.2.2. Πρότυπα ISO/IEC

- **ISO/IEC 27001:2013** – Ορίζει τις απαιτήσεις για ένα Σύστημα Διαχείρισης Ασφάλειας Πληροφοριών (ISMS), κρίσιμο για την αναγνώριση και διαχείριση κινδύνων σε περιβάλλοντα IoT [\[20\]](#).
- **ISO/IEC 27400:2019** – Κατευθυντήριες οδηγίες για τον σχεδιασμό και την υλοποίηση ελέγχων ασφάλειας και προστασίας προσωπικών δεδομένων σε λύσεις IoT [\[21\]](#).
- **ISO/IEC 29100:2011** – Παρέχει ένα ευρύ πλαίσιο ιδιωτικότητας με κοινή ορολογία, ρόλους και 11 βασικές αρχές προστασίας δεδομένων, ανεξάρτητα από τεχνολογίες και γεωγραφικά όρια [\[22\]](#).

4.2.3. Κατευθύνσεις NIST για το IoT

Το **NISTIR 8259** περιγράφει έξι θεμελιώδεις δραστηριότητες για τους κατασκευαστές IoT, με στόχο την ενίσχυση της ασφάλειας από το στάδιο ανάπτυξης μέχρι την αγορά [\[23\]](#). Το συμπληρωματικό **NISTIR 8259A** καθορίζει έξι βασικές δυνατότητες συσκευών (π.χ. μοναδική ταυτοποίηση, διαχείριση ενημερώσεων, προστασία δεδομένων) για ελάχιστα αποδεκτό επίπεδο ασφάλειας [\[24\]](#).

4.2.4. ETSI EN 303 645: Βασικές απαιτήσεις κυβερνοασφάλειας

Το ευρωπαϊκό πρότυπο **ETSI EN 303 645 V2.1.1 (2020-06)** αποτελεί το πρώτο παγκόσμιο πλαίσιο για την κυβερνοασφάλεια καταναλωτικών IoT συσκευών. Περιλαμβάνει 13 υψηλού επιπέδου απαιτήσεις και 33 υποχρεωτικές διατάξεις, επικεντρωμένες στην πρόληψη απλών αλλά συχνών επιθέσεων, όπως η απαγόρευση προκαθορισμένων κωδικών πρόσβασης και η ασφαλής διαχείριση ενημερώσεων [\[25\]](#)[\[26\]](#).



4.2.5. ITU-T Recommendations για το IoT

Η σύσταση **ITU-T Y.2060 (πρώην Y.4000)** ορίζει τους ορισμούς, τα χαρακτηριστικά και το μοντέλο αναφοράς του IoT, διασφαλίζοντας διαλειτουργικότητα και επεκτασιμότητα [\[27\]](#). Επιπλέον, το ITU προσφέρει τεχνικές κατευθύνσεις μέσω του IoT-GSI για «έξυπνες πόλεις» και ενσωματώνει σύγχρονες τεχνολογίες όπως blockchain και έξυπνη υγεία [\[28\]](#).

4.2.6. IEEE P2413 και Συναφείς Πρωτοβουλίες

Το **IEEE P2413-2019** στοχεύει στη δημιουργία ενός ενιαίου αρχιτεκτονικού πλαισίου IoT, προσδιορίζοντας κοινούς τομείς, συνιστώσες και υπηρεσίες για διαλειτουργικότητα μεταξύ κατακόρυφων αγορών [\[29\]](#). Συνεργάζεται με άλλα πρότυπα IEEE, όπως το **1451.0** για τη διασύνδεση αισθητήρων και το **2700** για επιδόσεις αισθητήρων, ώστε να υποστηρίζεται ένα πλήρες, ενιαίο οικοσύστημα.

5. Τεχνικές Προστασίας Ιδιωτικότητας

Η προστασία της ιδιωτικότητας σε περιβάλλοντα Internet of Things απαιτεί ολοκληρωμένη και πολυεπίπεδη προσέγγιση, δεδομένου του όγκου και της ευαισθησίας των δεδομένων που διακινούνται. Στο πρώτο επίπεδο, η κρυπτογράφηση εξασφαλίζει ότι οι πληροφορίες παραμένουν διαβαθμισμένες και προσβάσιμες αποκλειστικά από εξουσιοδοτημένους φορείς. Στη συνέχεια, η διαχείριση πρόσβασης και η ταυτοποίηση θεσπίζουν σαφείς κανόνες για την είσοδο σε συσκευές και πλατφόρμες, διασφαλίζοντας ότι μόνο έμπιστοι χρήστες ή υπηρεσίες έχουν τη δυνατότητα επεξεργασίας των δεδομένων. Τέλος, η εφαρμογή μεθόδων ανωνυμοποίησης και pseudonymization διακόπτει τη σύνδεση μεταξύ των δεδομένων και της ταυτότητας του υποκειμένου, περιορίζοντας σημαντικά τον κίνδυνο μη εξουσιοδοτημένης αναγνώρισης ή profiling. Η συνδυαστική χρήση αυτών των τεχνικών συνιστά τη βάση για τη διαμόρφωση ενός αξιόπιστου πλαισίου ιδιωτικής διαχείρισης στο IoT.

5.1 Κρυπτογράφηση δεδομένων

Η κρυπτογράφηση αποτελεί τον ακρογωνιαίο λίθο για την προστασία της εμπιστευτικότητας και της ακεραιότητας των δεδομένων σε ένα περιβάλλον



Internet of Things. Για την κατανόηση των μεθόδων προστασίας των IoT συσκευών, κρίνεται απαραίτητη η ουσιαστική κατανόηση τόσο των βασικών αρχών όσο και των πρακτικών περιορισμών που συνοδεύουν την εφαρμογή κρυπτογραφικών πρωτοκόλλων σε συσκευές με περιορισμένους πόρους.

Στο πλαίσιο του IoT, τα δεδομένα μεταφέρονται διαρκώς από τα «άκρα» (edge devices) προς τα κέντρα δεδομένων (cloud). Χωρίς κρυπτογράφηση, κάθε πακέτο που διέρχεται από δημόσια ή ημι-ιδιωτικά δίκτυα καθίσταται ευάλωτο σε υποκλοπές και επιθέσεις τύπου man-in-the-middle. Για τον λόγο αυτό, η χρήση πρωτοκόλλων TLS/DTLS σε συνδυασμό με σύγχρονους αλγορίθμους συμμετρικής κρυπτογράφησης, όπως το AES-128 και το AES-256, προσφέρει ένα αποδεδειγμένα ασφαλές επίπεδο προστασίας για μεταδεδομένα και φορτία χρήστη ^[6].

Ωστόσο, η απλή εγκατάσταση κρυπτογραφίας δεν επαρκεί. Σε πολλές IoT συσκευές, ο περιορισμένος επεξεργαστής και η ελάχιστη μνήμη καθιστούν προβληματική τη χρήση βαρέων αλγορίθμων ασύμμετρης κρυπτογράφησης (RSA, ECC) σε ευρεία κλίμακα. Για το λόγο αυτό, έχει αναπτυχθεί μια κατηγορία “lightweight” κρυπτογραφικών σχημάτων (π.χ. SPECK, PRESENT), η οποία συμμορφώνεται με τις κατευθυντήριες γραμμές του ISO/IEC 27400:2019, εξισορροπώντας την ασφάλεια με την αποδοτικότητα πόρων. ^[21]

Οι βασικές κατηγορίες κρυπτογράφησης που εφαρμόζουμε στο IoT είναι:

Συμμετρική κρυπτογράφηση, όπου ένα κοινό μυστικό κλειδί χειρίζεται κρυπτογράφηση και αποκρυπτογράφηση, ιδανική για συνεχή streaming δεδομένα, αλλά ευάλωτη εάν το κλειδί διαρρεύσει.

Ασύμμετρη κρυπτογράφηση, που βασίζεται σε ζεύγη δημοσίων/ιδιωτικών κλειδίων, εξασφαλίζοντας ασφαλή ανταλλαγή κλειδίων· συνήθως συνοδεύει συμμετρικές μεθόδους σε υβριδικά πρωτόκολλα για καλύτερη απόδοση.

Ελαφρές (lightweight) μέθοδοι, σχεδιασμένες να λειτουργούν με περιορισμένους πόρους, χωρίς να υποσκάπτουν την ανθεκτικότητα απέναντι σε βασικές επιθέσεις κρυπτανάλυσης.

Κατά την εφαρμογή, πρέπει να ληφθούν υπόψη οι ακόλουθες βέλτιστες πρακτικές:

End-to-end κρυπτογράφηση: Τα δεδομένα παραμένουν κρυπτογραφημένα από την αρχή έως το τέλος της διαδρομής τους, αποτρέποντας οποιαδήποτε ενδιάμεση



τροποποίηση ή υποκλοπή.

Ασφαλής διαχείριση κλειδιών: Η δημιουργία, αποθήκευση και τακτική ανανέωση (key rotation) των κλειδιών απαιτεί χρήση Hardware Security Modules (HSM) ή αξιόπιστων υπηρεσιών Key Management.

Συνεχής παρακολούθηση και ενημέρωση: Οποιοδήποτε πρωτόκολλο κρυπτογράφησης «φθείρεται» με τον χρόνο, καθώς ανακαλύπτονται νέες επιθέσεις· συνεπώς, η υποστήριξη για ασφαλείς αναβαθμίσεις είναι αδήριτη ανάγκη.

5.2 Διαχείριση Πρόσβασης και Ταυτοποίηση

Σε ένα περιβάλλον Internet of Things, η ικανότητα να ελέγχουμε αυστηρά ποιος έχει πρόσβαση σε ποιον πόρο και με ποιον τρόπο αποτελεί καθοριστικό παράγοντα για την ασφάλεια και την αξιοπιστία του συστήματος. Η ταυτοποίηση (authentication) επιβεβαιώνει την ταυτότητα μιας συσκευής ή χρήστη, ενώ η διαχείριση πρόσβασης (authorization) καθορίζει τα δικαιώματα που αφενός κατέχονται και αφετέρου εκτελούνται.

Η **ταυτοποίηση** στο IoT πρέπει να είναι ταυτόχρονα αξιόπιστη και ελαφριά – πολλές συσκευές λειτουργούν με περιορισμένους πόρους και απαιτούν ελάχιστη ανθρώπινη παρέμβαση. Για το λόγο αυτό, αξιοποιούνται ψηφιακά πιστοποιητικά X.509, πρωτόκολλα TLS/DTLS και, όλο και περισσότερο, αποκεντρωμένες λύσεις βασισμένες σε blockchain, οι οποίες εξαλείφουν την ανάγκη εμπιστοσύνης σε κεντρικούς διακομιστές [\[30\]](#). Παράλληλα, η πολυπαραγοντική ταυτοποίηση (MFA) συνδυάζει παράγοντες “κάτι που γνωρίζεις” (π.χ. κωδικός), “κάτι που έχεις” (π.χ. token, συσκευή) και “κάτι που είσαι” (βιομετρικά), προσφέροντας ακόμα πιο υψηλό επίπεδο ασφάλειας σε περιβάλλοντα ευαίσθητων εφαρμογών.

Η **διαχείριση πρόσβασης**, από την άλλη πλευρά, οργανώνει τα δικαιώματα χρήσης των πόρων μέσω πολιτικών βάσει ρόλων (RBAC) ή χαρακτηριστικών (ABAC). Στο μοντέλο RBAC, κάθε συσκευή ή χρήστης αποδίδεται σε έναν ή περισσότερους ρόλους (π.χ. “διαχειριστής”, “χρήστης”, “επισκέπτης”) και αποκτά αυτόματα τα αντίστοιχα δικαιώματα. Το ABAC, ωστόσο, επιτρέπει μεγαλύτερη ευελιξία, καθώς λαμβάνει υπόψη ιδιότητες όπως η ώρα της ημέρας, η τοποθεσία ή η κατάσταση της συσκευής για να αποφασίσει σε πραγματικό χρόνο αν η πρόσβαση είναι επιτρεπτή.



Κεντρικό στοιχείο κάθε σύγχρονης IoT λύσης είναι η αρχή του **ελάχιστου προνομίου** (least privilege): κάθε οντότητα διαθέτει μόνο τα απολύτως απαραίτητα δικαιώματα για τις λειτουργίες της. Σε συνδυασμό με διαχωρισμό καθηκόντων (separation of duties), αυτό μειώνει δραστικά τον αντίκτυπο μιας πιθανής παραβίασης, καθώς ακόμη και εάν διαρρεύσουν διαπιστευτήρια, ο επιτιθέμενος δεν αποκτά αυτόματα πλήρη έλεγχο συστήματος.

Στην πράξη, πολλές ευπαθείς IoT συσκευές φέρουν ακόμα προεπιλεγμένα ή “hard-coded” διαπιστευτήρια, χωρίς κανένα μηχανισμό υποχρεωτικής αλλαγής κατά την πρώτη διαμόρφωση. Το αποτέλεσμα είναι ότι εκτιθέμενα botnets, όπως το Mirai, μπόρεσαν να αναπτυχθούν αστραπιαία, χρησιμοποιώντας απλά παγκόσμια γνωστούς κωδικούς [3]. Η υιοθέτηση προτύπων όπως το ISO/IEC 27001, το ETSI EN 303 645 και οι οδηγίες του NISTIR 8259 A βοηθούν στον καθορισμό σαφών οδηγιών υλοποίησης πολιτικών πρόσβασης, από την ασφαλή έκδοση πιστοποιητικών μέχρι τη διαχείριση του κύκλου ζωής τους.

Τέλος, η διαρκής **παρακολούθηση** και **αναθεώρηση** των πολιτικών πρόσβασης αποτελούν βέλτιστη πρακτική: οι τακτικοί έλεγχοι ακεραιότητας διαπιστευτηρίων, η ανανέωση κωδικών και κλειδιών, καθώς και η αναθεώρηση των ρόλων με βάση τις πραγματικές ανάγκες διασφαλίζουν ότι το σύστημα παραμένει θωρακισμένο απέναντι στις εξελισσόμενες απειλές.

5.3 Ανωνυμοποίηση και Pseudonymization

Η ανωνυμοποίηση και η pseudonymization συνιστούν κρίσιμες τεχνικές για την ελαχιστοποίηση του κινδύνου ταυτοποίησης των υποκειμένων όταν διαχειριζόμαστε μεγάλα σύνολα δεδομένων σε περιβάλλοντα IoT. Αν και συχνά χρησιμοποιούνται αλληλοσυμπληρωματικά, έχουν διαφορετικό βαθμό “αίας” αποσύνδεσης των προσωπικών στοιχείων από τα δεδομένα.

Σε γενικές γραμμές, **ανωνυμοποίηση** σημαίνει τον μόνιμο μετασχηματισμό των δεδομένων ώστε να καθίσταται αδύνατη η ταυτοποίηση ενός προσώπου, ακόμα και αν συνδυάσουμε τα δεδομένα με εξωτερικές πηγές. Τεχνικές όπως η **k-ανωνυμία**, το **I-diversity** και το **t-closeness** εξαλείφουν ή γενικεύουν χαρακτηριστικά (π.χ. ηλικία σε ηλικιακές ομάδες, ταχυδρομικούς κώδικες σε γεωγραφικές ζώνες) με στόχο να εξασφαλίσουν ότι κάθε εγγραφή βρίσκεται σε πλήθος παρόμοιων εγγραφών [1]. Η εφαρμογή τους στο IoT απαιτεί προσοχή: δεδομένου του όγκου και της συνεχούς ροής δεδομένων, πρέπει να επιλέγονται αλγόριθμοι χαμηλής



πολυπλοκότητας και να προσαρμόζονται δυναμικά στα streams, ώστε να μην υποβαθμίζεται η απόδοση των συσκευών.

Αντίθετα, η **pseudonymization** αντικαθιστά τα αναγνωριστικά πεδία (όνομα, αναγνωριστικό συσκευής κ.λπ.) με ψευδώνυμα ή token, διατηρώντας σε ξεχωριστή, ασφαλή βάση τη σχέση μεταξύ των ψευδωνύμων και των πραγματικών ταυτοτήτων. Αυτό προσφέρει ευελιξία: εάν χρειαστεί να επανεντοπιστεί ένα υποκείμενο —π.χ. για υποχρεώσεις συμμόρφωσης ή διαχείριση παραπόνων— η αντιστοίχιση είναι δυνατή, με την προϋπόθεση ότι ο πίνακας σύνδεσης προστατεύεται κατάλληλα [\[1\]](#). Σε εφαρμογές IoT, μια συσκευή μπορεί να στέλνει συνεχώς ανώνυμα μετρήσεις στο cloud, ενώ οι αρμόδιοι administrators, μέσω ασφαλούς κλειδιού, μπορούν όποτε απαιτείται να “ξεψαχνίσουν” ποια συσκευή απέστειλε ποια δεδομένα.

Η επίτευξη ουσιαστικής προστασίας βασίζεται στη **συνδυαστική** χρήση των δύο μεθόδων:

- **Πρώτο στάδιο**, pseudonymization των ευαίσθητων identifiers σε επίπεδο συσκευής ή χρήστη.
- **Δεύτερο στάδιο**, ανωνυμοποίηση ή γενίκευση των πεδίων μεταδεδομένων πριν από τη δημοσίευση ή την ανάλυση.

Με αυτόν τον τρόπο, ακόμα και σε περίπτωση υποκλοπής ή κακόβουλης χρήσης, τα δεδομένα δεν παρέχουν επαρκή πληροφορία για μεμονωμένη ταυτοποίηση ή profiling συμπεριφοράς.

Τελειώνοντας, η επιλογή και η υλοποίηση των κατάλληλων αλγορίθμων ανωνυμοποίησης και pseudonymization πρέπει να εναρμονίζεται με τις προδιαγραφές του **ISO/IEC 20889:2018**, που ορίζει ορολογία, κατηγορίες και μετρικές αξιολόγησης της αποτελεσματικότητας της απο-ταυτοποίησης [\[1\]](#). Παράλληλα, μελέτες όπως αυτή των **Ma et al. (2021)** καταδεικνύουν πώς ειδικά σχεδιασμένα πρωτόκολλα για διαρκή ροή δεδομένων IoT διασφαλίζουν την ισορροπία ανάμεσα στην προστασία ιδιωτικότητας και τη διατηρησιμότητα της πληροφορίας. [\[31\]](#)

6. Προκλήσεις και Μελλοντικές Τάσεις

Στο επόμενο κεφάλαιο θα κάνουμε ένα ουσιαστικό ταξίδι στις πιο σύνθετες προκλήσεις και τις δυναμικές εξελίξεις που διαμορφώνουν το μέλλον της ιδιωτικότητας στο IoT. Πρώτα, στην ενότητα 6.1, θα δούμε πώς η τεχνητή νοημοσύνη και η μηχανική μάθηση μπορούν να λειτουργήσουν ως ισχυρά εργαλεία



τόσο στην πρόληψη και την ανίχνευση απειλών όσο και στον αθέατο κίνδυνο εκτεταμένης παρακολούθησης των χρηστών. Στη συνέχεια, στην ενότητα 6.2, θα εξετάσουμε πώς το blockchain υπόσχεται να φέρει διαφάνεια και ακεραιότητα στις συναλλαγές των δεδομένων, αλλά και ποια είναι τα πρακτικά εμπόδια στην υιοθέτησή του σε μεγάλης κλίμακας δίκτυα IoT. Με αυτή την προσέγγιση, επιδιώκουμε να αποτυπώσουμε όχι απλώς τις τεχνολογικές δυνατότητες, αλλά και τις πραγματικές απαιτήσεις για ένα ασφαλές και ανθρώπινο μέλλον στο Internet of Things.

6.1 AI/ML στο IoT και Ιδιωτικότητα

Στην ενότητα αυτή εξετάζουμε πώς η τεχνητή νοημοσύνη (AI) και η μηχανική μάθηση (ML) επηρεάζουν την ιδιωτικότητα σε περιβάλλοντα IoT. Θα δούμε τόσο τις δυνατότητες που προσφέρουν για τον εντοπισμό και την άμυνα απέναντι σε απειλές όσο και τους νέους κινδύνους που δημιουργούν όταν προσωπικά δεδομένα χρησιμοποιούνται για εκπαίδευση και λειτουργία αλγορίθμων. Η ισορροπία ανάμεσα στην αποδοτικότητα και την προστασία της ιδιωτικότητας είναι κρίσιμη για την ευρεία υιοθέτηση ασφαλών IoT λύσεων [\[11\]](#).

6.1.1 Ανίχνευση Απειλών με AI/ML

Οι αλγόριθμοι ML μπορούν να μάθουν από πρότυπα συνηθισμένης συμπεριφοράς σε δίκτυα IoT και να εντοπίζουν ανώμαλες δραστηριότητες σε πραγματικό χρόνο, όπως προσπάθειες brute-force ή εκμετάλλευση ευπαθειών firmware. Σύμφωνα με μελέτη, τεχνικές όπως τα ανώτερα νευρωνικά δίκτυα και η ανάλυση στιγμιαίων ακολουθιών (time-series analysis) επιτυγχάνουν υψηλό ποσοστό ανίχνευσης εισβολών, ξεπερνώντας κατά πολύ τους παραδοσιακούς κανόνες υπογραφής [\[11\]](#).

6.1.2 Νέοι Κίνδυνοι για την Ιδιωτικότητα

Παρά τις αδιαμφισβήτητες δυνατότητες, η χρήση AI/ML συστήνει αυξημένο κίνδυνο διαρροής προσωπικών δεδομένων. Οι αλγόριθμοι απαιτούν τεράστια σύνολα δεδομένων για εκπαίδευση, και όταν αυτά προέρχονται από IoT αισθητήρες (π.χ. φορητές συσκευές υγείας), μπορεί να περιέχουν ευαίσθητα βιομετρικά ή συμπεριφορικά στοιχεία. Χωρίς κατάλληλα μέτρα, η εσωτερική αναγνώριση



μοτίβων μπορεί να οδηγήσει σε ανεπιθύμητο profiling και επακόλουθη παραβίαση της ιδιωτικότητας των χρηστών [\[12\]](#).

6.1.3 Federated Learning και Προστασία Δεδομένων

Μία καινοτόμος προσέγγιση για να μειωθούν οι κίνδυνοι είναι το federated learning, όπου τα δεδομένα παραμένουν τοπικά στη συσκευή και μόνο τα ενημερωμένα μοντέλα («βαρίδια μάθησης») αποστέλλονται σε κεντρικό διακομιστή. Αυτό ελαχιστοποιεί την ανάγκη διαμοιρασμού ακατέργαστων δεδομένων και μειώνει την πιθανότητα υποκλοπής ευαίσθητων πληροφοριών. Έρευνες δείχνουν ότι, αν και υφίστανται προκλήσεις ως προς τη συναρμολόγηση και την ασφάλεια των ενημερώσεων, το federated learning μπορεί να διατηρήσει υψηλή ακρίβεια εντοπισμού απειλών, οδηγώντας σε πιο ιδιωτικά και επεκτάσιμα IoT συστήματα [\[12\]](#).

6.1.4 Μελλοντικές Προκλήσεις

Η ένταξη AI/ML στο IoT απαιτεί την εξέλιξη των τεχνικών anonymization και differential privacy, ώστε οι αλγόριθμοι να μαθαίνουν χωρίς να αποκαλύπτουν προσωπικά δεδομένα. Παράλληλα, η διαρκής αξιολόγηση του αλγορίθμου για biases και η διαφάνεια στη λειτουργία του θα καθορίσουν σε μεγάλο βαθμό την αποδοχή από την πλευρά των τελικών χρηστών και των ρυθμιστικών φορέων [\[8\]](#).

6.2 Blockchain και διασφαλίσεις

Η τεχνολογία blockchain προσφέρει στο Internet of Things ένα μηχανισμό αποκεντρωμένης καταγραφής γεγονότων, εξασφαλίζοντας την αμεταβλητότητα και τη διαφάνεια των συναλλαγών δεδομένων. Σε ένα περιβάλλον όπου εκατομμύρια συσκευές ανταλλάσσουν συνεχώς πληροφορίες, η ύπαρξη ενός κατανεμημένου καθολικού (distributed ledger) μειώνει την ανάγκη εμπιστοσύνης σε κεντρικούς διακομιστές και παρέχει ανεξάρτητη επιβεβαίωση της ορθότητας των δεδομένων [\[32\]](#).

Παρά τις θεωρητικές δυνατότητες, η κλιμάκωση παραμένει βασική πρόκληση. Τα συμβατικά πρωτόκολλα consensus, όπως Proof-of-Work, απαιτούν σημαντικούς υπολογιστικούς πόρους και ενέργεια, χαρακτηριστικά που συγκρούονται με τους περιορισμούς επεξεργαστικής ισχύος και αυτονομίας των περισσότερων IoT συσκευών [\[33\]](#). Επιπλέον, ο χρόνος επιβεβαίωσης συναλλαγών σε μεγάλης κλίμακας



δίκτυα συχνά υπερβαίνει τα όρια όπου απαιτείται σχεδόν σε πραγματικό χρόνο ανταπόκριση, γεγονός που θέτει περιορισμούς σε εφαρμογές όπως η βιομηχανική αυτοματοποίηση ή η υγεία.

Για να αντιμετωπιστούν αυτά τα εμπόδια, έχουν προταθεί ελαφριά σχήματα consensus και αρχιτεκτονικές edge-blockchain: οι τοπικοί κόμβοι blockchain στους 'άνω άκρους' του δικτύου αναλαμβάνουν ένα μέρος του φορτίου, ενώ το κύριο καθολικό συγχωνεύει περιοδικά τα νέα blocks· έτσι μειώνεται η καθυστέρηση και το ενεργειακό κόστος για τις περιφερειακές συσκευές [\[34\]](#). Επιπλέον, μηχανισμοί όπως το Proof-of-Stake ή DAG-based μοντέλα (π.χ. IOTA Tangle) προσφέρουν υψηλότερη κλίμακα με σημαντικά χαμηλότερη κατανάλωση πόρων, διατηρώντας παράλληλα ακεραιότητα και ανθεκτικότητα.

Καταλήγοντας, η ενσωμάτωση blockchain στο IoT δεν αρκεί να βασίζεται στις τεχνολογικές δυνατότητες· απαιτείται επίσης ολοκληρωμένη προσέγγιση στη διαχείριση κλειδιών, στην ασφάλεια των κόμβων και στην εναρμόνιση με τα νομικο-ρυθμιστικά πλαίσια, ώστε να διασφαλιστεί ότι η αποκέντρωση δεν μετατρέπεται σε νέο σημείο ευπάθειας.

Συμπέρασμα

Η ανάλυση του ευρύτερου οικοσυστήματος IoT ανέδειξε πολύπλευρα ζητήματα ιδιωτικότητας, τα οποία συνδέονται άμεσα με τα χαρακτηριστικά των συσκευών και των δικτύων τους, καθώς και με το θεσμικό και τεχνολογικό πλαίσιο λειτουργίας τους.

Καταγράφηκαν οι κύριες απειλές – όπως η χρήση αδύναμων διαπιστευτηρίων, οι ευπάθειες σε πρωτόκολλα επικοινωνίας, η ανεπαρκής διαχείριση ενημερώσεων λογισμικού και η μη κρυπτογραφημένη αποθήκευση δεδομένων – που συχνά διευκολύνουν σύνθετες επιθέσεις, συμπεριλαμβανομένου του σχηματισμού botnets. Διαπιστώθηκε, επίσης, ότι η εφαρμογή του GDPR και η τήρηση διεθνών προτύπων (ISO, NIST, ETSI) αποτελούν βασικό στοιχείο για τη συμμόρφωση και την ενίσχυση της ασφάλειας. Παρουσιάστηκαν τεχνικές προστασίας (κρυπτογράφηση, διαχείριση πρόσβασης/ταυτοποίηση, ανωνυμοποίηση/pseudonymization) που συγκροτούν ένα συνεκτικό πλαίσιο ασφαλείας για συστήματα IoT.

Όσον αφορά τις μελλοντικές τάσεις, η ενσωμάτωση μεθόδων AI/ML μπορεί να βελτιώσει σημαντικά την ανίχνευση και πρόληψη απειλών, ενώ ταυτόχρονα εισάγει νέα ζητήματα διαχείρισης και προστασίας ευαίσθητων δεδομένων. Η αξιοποίηση



της τεχνολογίας blockchain προσφέρει αδιαμφισβήτητη ακεραιότητα και διαφάνεια, όμως οι περιορισμοί σε υπολογιστικούς πόρους, ταχύτητα συναλλαγών και νομικό πλαίσιο αναδεικνύουν την ανάγκη για ελαφρύτερα σχήματα consensus και ολοκληρωμένες πολιτικές διαχείρισης κλειδιών.

Προτάσεις για περαιτέρω έρευνα και δράση

Εξέταση ελαφρών κρυπτογραφικών σχημάτων βελτιστοποιημένων για περιορισμένους πόρους IoT.

Διαμόρφωση συστημάτων συνεχούς επιτήρησης των μηχανισμών προστασίας προσωπικών δεδομένων, με έμφαση σε πλαίσια federated learning, ώστε να ανιχνεύονται και να αντιμετωπίζονται άμεσα τυχόν παραβιάσεις ιδιωτικότητας.

Συστηματική εναρμόνιση ρυθμιστικών πλαισίων σε διεθνές επίπεδο, ώστε να διασφαλίζεται ομοιόμορφη προστασία.

Ανάπτυξη εξειδικευμένων προγραμμάτων επιμόρφωσης για τους σχεδιαστές και κατασκευαστές, σε συνδυασμό με διανομή στοχευμένων εκπαιδευτικών οδηγιών προς τους τελικούς χρήστες, ώστε να ελαχιστοποιηθούν τα σφάλματα κατά την αρχική ρύθμιση και την καθημερινή λειτουργία των IoT συσκευών.

Η ορθή εφαρμογή των παραπάνω δράσεων αναμένεται να ενισχύσει την εμπιστοσύνη όλων των εμπλεκόμενων μερών και να θέσει τα θεμέλια για ένα ασφαλέστερο και περισσότερο ανθρωποκεντρικό IoT μέλλον.



Αναφορές

1. ISO. "ISO/IEC 20889:2018 – Privacy enhancing data de-identification terminology and classification of techniques". <https://www.iso.org/standard/69373.html>
2. Yang, Y., Wu, L., Yin, G., Li, L., & Zhao, H. (2017). *A Survey on Security and Privacy Issues in Internet-of-Things*. IEEE Internet of Things Journal. https://www.researchgate.net/publication/316173391_A_Survey_on_Security_and_Privacy_Issues_in_Internet-of-Things_ResearchGate
3. Sicari, S., Rizzardi, A., Grieco, L. A., & Coen-Porisini, A. (2015). *Security, privacy and trust in Internet of Things: The road ahead*. Computer Networks, 76, 146–164. <https://www.sciencedirect.com/science/article/abs/pii/S1389128614003971> [ScienceDirect](#)
4. Atamli, A. W. & Martin, A. (2014). *Threat-Based Security Analysis for the Internet of Things*. 2014 International Workshop on Secure Internet of Things (SIoT), pp. 35–43.
5. Fernandes, E., Jung, J. & Prakash, A. (2016). *Security Analysis of Emerging Smart Home Applications*. IEEE Symposium on Security and Privacy, May 2016. https://www.earlence.com/assets/papers/smartthings_sp16.pdf [earlence.com](#)
6. GDPR (Regulation (EU) 2016/679). *Official Text* – gdpr-info.eu (OJ L 119, 04.05.2016). <https://gdpr-info.eu/gdpr-info.eu>
7. EUR-Lex: Regulation (EU) 2016/679 of 27 April 2016 (General Data Protection Regulation). <https://eur-lex.europa.eu/eli/reg/2016/679/oj/eng> [EUR-Lex](#)
8. Hou, J., Qu, L. & Shi, W. (2019). *A Survey on Internet of Things Security from Data Perspectives*. Computer Networks, 148, 295–306. <https://doi.org/10.1016/j.comnet.2018.11.026> [SCIRP](#)
9. Latif, S., Idrees, Z., Ahmad, J., Zheng, L. & Zou, Z. (2021). *A blockchain-based architecture for secure and trustworthy operations in the Industrial Internet of Things*. Journal of Industrial Information Integration, 21, 100190. <https://www.iiisci.org/journal/PDV/sci/pdfs/SA653MZ21.pdf> [iiisci.org](#)
10. Zhang, B., Chen, C. & Lee, I. (2025). *A Survey on Security and Privacy Issues in Wearable Health Monitoring Devices*. Computers & Security, 155, 104453. <https://doi.org/10.1016/j.cose.2025.104453> [ResearchGate](#)
11. Al-Garadi, M. A. et al. (2020). *A Survey of Machine and Deep Learning Methods for Internet of Things (IoT) Security*. IEEE Communications Surveys & Tutorials, 22(3), 1646–1685. <https://ieeexplore.ieee.org/document/9060812> [ijcna.org](#)



12. Briggs, C., Fan, Z. & Andras, P. (2020). *A Review of Privacy-preserving Federated Learning for the Internet-of-Things*. arXiv:2004.11794.
<https://arxiv.org/abs/2004.11794> [arXiv](#)
13. Heather Landi, “Fitbit, Apple user data exposed in breach impacting 61M fitness tracker records,” *FierceHealthcare*, Sep 13, 2021 [fiercehealthcare.com](https://www.fiercehealthcare.com)
14. Federal Trade Commission, “FTC Says Ring Employees Illegally Surveilled Customers,” May 2023 [Federal Trade Commission](https://www.ftc.gov)
15. InfoSecurity Magazine, “Exclusive: Massive IoT Data Breach Exposes 2.7 Billion Records,” Feb 2025 [infosecurity-magazine.com](https://www.infosecurity-magazine.com)
16. Conosco, “Household Appliances – Botnet Attacks,” Jan 2021 [Conosco](https://www.conosco.com)
17. Mozilla Foundation, “August Smart Locks | Privacy & security guide,” 2019
18. OECD. “Recommendation of the Council concerning Guidelines Governing the Protection of Privacy and Transborder Flows of Personal Data.” OECD Publishing, 23 Σεπτεμβρίου 1980.
19. OECD. “Guidelines on the Protection of Privacy and Transborder Flows of Personal Data (2013 Update).” OECD Publishing, 28 Νοεμβρίου 2013.
20. ISO/IEC. “ISO/IEC 27001:2013 – Information technology – Security techniques – Information security management systems – Requirements.” International Organization for Standardization, 2013.
21. ISO/IEC. “ISO/IEC 27400:2019 – Information technology – Security techniques – Privacy guidelines for the design and implementation of IoT.” International Organization for Standardization, 2019.
22. ISO/IEC. “ISO/IEC 29100:2011 – Information technology – Security techniques – Privacy framework.” International Organization for Standardization, 2011.
23. NIST. “Security and Privacy Controls for IoT (NISTIR 8259).” National Institute of Standards and Technology, Απρίλιος 2019.
24. NIST. “Device Cybersecurity Guidance (NISTIR 8259A).” National Institute of Standards and Technology, Μάρτιος 2020.
25. ETSI. “ETSI EN 303 645 V2.1.1 (2020-06) – Cyber Security for Consumer Internet of Things: Baseline Requirements.” European Telecommunications Standards Institute, Ιούνιος 2020.



26. ITU-T. “Y.2060 (formerly Y.4000) – Overview of the Internet of Things.” ITU-Telecommunication Standardization Sector, Φεβρουάριος 2012.
27. IEEE. “P2413-2019 – Standard for an Architectural Framework for the Internet of Things (IoT).” IEEE Standards Association, 2019.
28. IEEE. “IEEE 1451.0 – IEEE Standard for a Smart Transducer Interface for Sensors and Actuators – Common Functions, Communication Protocols, and Transducer Electronic Data Sheet (TEDS) Formats.” IEEE Standards Association, 2010.
29. IEEE. “IEEE 2700-2017 – Standard for Sensor Performance Parameter Definitions.” IEEE Standards Association, 2017.
30. Latif, S., Idrees, Z., Ahmad, J., Zheng, L. & Zou, Z. (2021). *A blockchain-based architecture for secure and trustworthy operations in the Industrial Internet of Things*. Journal of Industrial Information Integration, 21, 100190.
31. K. Ma, H. Zhou & L. Sun (2021). “Data privacy in the Internet of Things based on anonymization.” *Journal of Cyber Security*, DOI:10.3233/JCS-210089
32. Rahman, Z. et al. (2022). “Blockchain Applicability for the Internet of Things: Performance and Scalability Challenges and Solutions.” arXiv:2205.00384.
33. Moudoud, H., Cherkaoui, S. & Khoukhi, L. (2022). “Towards a Scalable and Trustworthy Blockchain: IoT Use Case.” arXiv:2201.11337.
34. Gadekallu, T. R. et al. (2021). “Blockchain for Edge of Things: Applications, Opportunities, and Challenges.” arXiv:2110.05022.